
Lyng C of E Primary School, Audit Report**Audit Date: 5 February 2020****Report: Year 2 visit 2****DPE: Linda Mortimer****School member: Headteacher – Helen Watson / School Secretary – Maria Rudd**

1. Visit details

Details highlighted at the time of the last visit were discussed. GDPR documents and policies were also reviewed. This included DPE Best Practice areas, Compliance Checklists, SLA tool, Record of Processing and Compliance Manager being discussed and demonstrated to the school. The themed audit carried out by NCC in Summer Term 2019 was also talked through (refer to section 6 below) as well as when the need arises for completing a Data Protection Impact Assessment (DPIA), (refer to section 5.1 below).

Review actions recommended at time of previous visit – 21.3.19**Reception/visitor signing in sheet:**

The school has considered using alternative methods for signing-in visitors; however, these are expensive. They have decided to maintain the current 'open book' system but now archive completed sign-in sheets. The office is aware of the signing in protocol for visiting professionals, and always make sure that student names are not noted in the book.

Bus driver lists:

These lists of students are now first name only, and stored securely in a locked office.

Front office privacy screen:

The School had purchased, but the screen caused issues with viewing. The school has reviewed the current arrangement and the monitor is closed or locked when visitors / parents are at the hatch.

Front office key cabinet:

School will change their current practice, and the key to the key cabinet will be stored securely at night.

Staffroom:

Care plans: now include first name only. Full copies of care plans are kept in a locked cabinet in the main office

Printer codes:

The school will contact Konica Minolta to arrange pin code print retrieval system.

Action: Contact with Mark Hardy at Konica Minolta to arrange confidential print retrieval system.

Server and school back up:

The server is in an area that is easily accessible, and backups are easily removed.

This arrangement is still in place and the server remains easily accessible. The external, separate hard disk remains vulnerable.

Actions re Server:

School to check with IT Technician what is backed up to the external hard disk – are back-ups made to the Cloud?

Check with IT Technician to see if the server can be secured to the floor using Kensington lock – see link:

<https://www.kensington.com/en-gb/c/products/security/desktop-locking-solutions/?srt=relevance>

Check with IT Technician that server back-ups are encrypted as the current hard disk is extremely vulnerable to loss or theft.

iPads: Photos easily accessed.

Action: The school is still to develop robust procedures to ensure photos are removed/uploaded to a secure area on the server. This should be carried out on a regular basis. A robust procedure for cleansing of iPads is already in place in EYFS.

Archiving: There are now archive folders for each year group, on the school server. These have restricted access. EYFS regularly use this system for their archiving of student images routinely used for recording Learning Journeys.

Audit walk findings on 5.2.20

Privacy Notice: The link to this document was not evident on the school website. Visitors and parents should be signposted to the location of the school's Privacy Notice ie the school website. The school needs to provide a more detailed list of third parties with whom they share personal data. An example list will be provided.

Publication Scheme: This was discussed and examples will be provided for the school to make reference to. More guidance can be found under the News tab on the Knowledge Bank.

Staff Training: All staff have completed GDPR 101. A GDPR 20-minute refresher course will be available shortly on Knowledge Bank. DPE recommend that staff should refresh their training every 2 years.

Consent Forms: School has recently reviewed its' consent forms based on DPE model, and includes social media; Facebook, Twitter.

Naming convention: All exercise books, work trays, files, displays and coat pegs use first names only.

Laptops: Are encrypted, password protected and accounted for on a regular basis. Following discussions at staff meetings all staff are aware of the Working Away from School Policy.

Action: School to share the Working Away from School Policy with all staff. This can be managed via Compliance Manager on Knowledge Bank.

iPads: Are password protected and accounted for on a regular basis.

Action: Check with IT Technician that iPads have 'Find my iPad' and 'Return to Factory Settings' installed.

School Kitchen: Operated by Norse Catering. All allergy information is kept securely.

Staffroom: There was no confidential paperwork or paperwork detailing PII data found in staff pigeonholes.

First Aid Records and Medical Student Care Plans: Are stored securely in a locked cabinet in the main office.

School Server: The school needs to introduce a robust procedure for cleansing out of date information and student images from the school server.

Willow Classroom: Cabinet containing confident student files was left unlocked, in an empty classroom.

Encryption: The Headteacher will seek advice from the school's IT Technician regarding encryption of PDF documents.

2. Compliance actions that should now be completed

Initial documents:

- Privacy Notice
- GDPR Policy
- Data Breach Procedure
- SAR procedure
- Photo and Video consent, guidelines and records

Ideally you would also have: Work away from school, clear desk and screen, information classification and record management policy/paperwork. Schools have either adopted the DPE models or incorporated some of this within their staff handbook, for example, work away from school.

The following should also be completed:

- There should be no named person on any of the above documents. If there is a named person i.e. Stuart Lee, the name needs replacing with: Data Protection Education Ltd;
- The Privacy Notice should have an appendix with your third-party suppliers listed. You should also make sure suppliers are GDPR compliant;
- The Privacy Notice, GDPR Policy and consent withdrawal form should be displayed on the school website;
- All staff should know what the data procedure is, and the document should be circulated to all staff;
- Key staff responding to SARs should have access to the SAR procedure and understand their responsibilities.

2.1. Data retention schedule:

By now you should be working through both physical and electronic data and have a good understanding of what data you hold and be documenting this. There are a number of documents available to support the process:

- Governor hub: annual review of school data and safe data destruction checklist
- IRMS toolkit: https://c.ymcdn.com/sites/irms.site-ym.com/resource/collection/8BCEF755-0353-4F66-9877-CCDA4BFEEAC4/2016_IRMS_Toolkit_for_Schools_v5_Master.pdf
- DfE toolkit
https://assets.publishing.service.gov.uk/government/uploads/system/uploads/attachment_data/file/747620/Data_Protection_Toolkit_for_Schools_OpenBeta.pdf (Annex 5,1)

2.2. Staff training

GDPR training has been completed and documented for the majority of staff. If not already you should:

- Rollout training to key staff and then consider all staff completing the e-learning training;
- Add as part of the induction process for new staff;
- Use staff meetings/briefings to raise staff awareness.

2.3. Governance check

It should form part of governance that GDPR is an item at governor meetings and to share reports with governors. Ideally the governor responsible for GDPR will have completed some form of GDPR training.

2.4. Make sure DPE is your registered DPO with the ICO

Not only do you need to be registered as a controller with the ICO, it is a requirement to register who your DPO is. The guide to complete this is available from the News section of the DPE website: <https://kb.dataprotection.education/news-top/news/83-best-practice-updates/110-make-sure-dpe-is-your-registered-dpo-with-the-ico>

3. Freedom of Information and Publication Scheme

The DPE GDPR policy and FOI policy content refer to the organisation having a publication scheme - do you have one? **The template for a model publication scheme can be obtained from:** <https://ico.org.uk/media/for-organisations/documents/1235/definition-document-schools-in-england.pdf> How to complete a publication scheme guide can be obtained from: <https://ico.org.uk/media/for-organisations/documents/1242/how-to-complete-template-guide-to-info-for-schools.pdf> Additional guidance can be obtained from the news section of the DPE website: <https://kb.dataprotection.education/news-top/news>

4. Technical measures

DPE recommends schools complete the Cyber essentials questionnaire available from: DPE>Resources> Information Technology Security: <https://kb.dataprotection.education/best-practice-library/documents/information-technology-security/7-crest-cyber-essentials-questionnaire>;

Check iPad/Tablet security. Are all laptops encrypted, does your end of day routines include housekeeping to remove data no longer needed and is equipment secured? Do staff still use unencrypted memory sticks? DPE recommends schools develop procedures to ensure iPads can be accounted for daily and data (i.e photos) can be cleared if lost or stolen ([Erase your device](#))

5. Next steps

Record of Processing (RoP) tool and data mapping

DPE have started to populate the Record of Processing (RoP) tool. Rather than each school complete individually, DPE will be populating as many processes as possible and then work with you to complete for your school. It is a requirement under article 30 of the GDPR and will form part of the basis for future remote sessions and visits.

5.1. Data Protection Impact Assessments (DPIA)

When processing high risk personal data and using new technologies (i.e. moving to a new technology for Safeguarding) a DPIA should be completed and the DPO consulted (Article 35.2). DPIAs offer a risk assessment template where concerns can be noted alongside mitigating actions to reduce the overall risks related to change of practice. It is good practice to complete a DPIA for any major project where the processing of personal data is required. DPE will be providing more guidance, training and include risk management within the RoP tool. Always contact DPE in the first instance.

6. Norfolk County Council Summer GDPR audits

NCC auditors completed several themed GDPR audits during the summer term 2019. DPE have provided feedback to the findings which can be obtained from the News section of the DPE website: <https://kb.dataprotection.education/news-top/news>